

Informe de Análisis Estático de Seguridad (SAST)

Proyecto: ADM Tarea2
Fecha del Reporte: 26 de mayo de 2026
Total de Hallazgos: 10 problemas detectados
Esfuerzo Total de Corrección (Technical Debt): 90 minutos

1. Resumen Ejecutivo

El análisis automatizado identificó **10 incidentes** distribuidos entre problemas de seguridad (Vulnerabilidades) y mantenibilidad del código (Code Smells).

Métricas Clave

- Vulnerabilidades:** 3
- Malos Olores de Código (Code Smells):** 7
- Deuda Técnica Total:** 1h 30min

Distribución por Severidad e Impacto

Severidad (SonarQube)	Cantidad	Impacto en Software Quality
MAJOR (Alta)	5	SECURITY (3) / MAINTAINABILITY (2)
MINOR (Baja)	4	MAINTAINABILITY (4)
INFO (Informativa)	1	MAINTAINABILITY (1)

2. Detalle de Vulnerabilidades de Seguridad (Impacto: SECURITY)

Esta sección contiene los hallazgos críticos que afectan directamente a la postura de seguridad de la aplicación móvil. **Se recomienda priorizar su resolución.**

Vulnerabilidad 1: Ofuscación Deshabilitada en Configuración de Release

- **Regla:** kotlin:S7204
- **Severidad:** MAJOR | **Impacto:** HIGH
- **Ubicación:** build.gradle.kts (Línea 37)
- **Asignado a:** bfariello-7GDcM@github
- **Descripción:** La configuración actual no asegura que la ofuscación de código (ej. ProGuard/R8) esté habilitada para la variante de producción (*release*). Esto facilita la ingeniería inversa de la aplicación.
- **Remediación:** Asegúrate de configurar `isMinifyEnabled = true` dentro del bloque `release` en tu archivo Gradle.

Vulnerabilidad 2: Envío de Intents No Seguro (Broadcasts)

- **Regla:** kotlin:S5320
- **Severidad:** MAJOR | **Impacto:** MEDIUM
- **Ubicación:** src/main/java/com/misitioweb/admTarea2/ui/BookViewModel.kt (Línea 134)
- **Descripción:** Se están enviando mensajes de tipo *Broadcast Intent* sin especificar restricciones. Otras aplicaciones maliciosas instaladas en el dispositivo podrían interceptar estos mensajes.
- **Remediación:** Utiliza *Intents* explícitos especificando el paquete destino, o restringe el alcance usando permisos o `LocalBroadcastManager` si la comunicación es interna.

Vulnerabilidad 3: Versiones de Dependencias Impredecibles (Falta de Lock File)

- **Regla:** text:S8569
- **Severidad:** MAJOR | **Impacto:** MEDIUM
- **Ubicación:** build.gradle.kts
- **Descripción:** El proyecto no cuenta con un archivo de bloqueo de dependencias (`gradle.lockfile` o `verification-metadata.xml`). Esto expone al proyecto a que se descarguen versiones diferentes o potencialmente comprometidas (ataques de cadena de suministro) en futuras compilaciones.
- **Remediación:** Habilita el control de versiones bloqueadas de Gradle (*Dependency Locking*) o la verificación de firmas de metadatos.

3. Detalle de Code Smells (Impacto: MAINTAINABILITY)

Problemas relacionados con la calidad, legibilidad y el mantenimiento del código a largo plazo.

Uso de Código Deprecado (Obsoleto)

Se encontraron **4 instancias** de uso de APIs obsoletas que deberían reemplazarse para evitar fallas en futuras actualizaciones de librerías o del SDK de Android (Severidad: **MINOR**, Esfuerzo: 15 min cada una):

1. FavoritesScreen.kt (Línea 119) - *Mensaje: Deprecated code should not be used.*
2. HomeScreen.kt (Línea 67) - *Mensaje: Deprecated code should not be used.*
3. ResultsScreen.kt (Línea 74) - *Mensaje: Deprecated code should not be used.*
4. SettingsScreen.kt (Línea 106) - *Mensaje: Deprecated code should not be used.*

Parámetros No Utilizados

- **Ubicación:** SettingsScreen.kt (Línea 23)
- **Severidad:** MAJOR | **Regla:** kotlin:S1172
- **Descripción:** La función recibe el parámetro "navController" pero no lo utiliza dentro de su cuerpo.
- **Remediación:** Remueve el parámetro de la firma de la función si no es requerido o impleméntalo si quedó pendiente.

Código Comentado (Limpieza)

- **Ubicación:** src/main/res/xml/backup_rules.xml (Líneas 9-12)
- **Severidad:** MAJOR | **Regla:** xml:S125
- **Descripción:** Bloque de código XML que se encuentra comentado. Ensucia el archivo y dificulta la lectura.
- **Remediación:** Eliminar las líneas comentadas; para el historial ya existe el control de versiones (Git).

Tareas Pendientes (TODO)

- **Ubicación:** src/main/res/xml/data_extraction_rules.xml (Línea 8)
- **Severidad:** INFO | **Regla:** xml:S1135
- **Descripción:** Existe un comentario "TODO" que indica una tarea de desarrollo pendiente por completar.

4. Plan de Acción Recomendado

1. **Fase 1 - Inmediata (Seguridad):** Habilitar la ofuscación en `build.gradle.kts` para mitigar el riesgo alto de ingeniería inversa, y securizar el *Broadcast* en `BookViewModel.kt`.
2. **Fase 2 - Estabilidad:** Generar el archivo de bloqueo de dependencias en Gradle para asegurar construcciones deterministas.
3. **Fase 3 - Refactorización:** Limpiar el parámetro sin usar en `SettingsScreen.kt` y el código comentado en `backup_rules.xml`.
4. **Fase 4 - Modernización:** Planificar la sustitución del código deprecated en las 4 pantallas de la interfaz de usuario (*UI Screens*).